Nidhi Rane
4401042607S

Case Study 2.

Page No.
Date

2/10/26

Case Study :- Securing the University Examination System

A university uses an Operating System-based examination management system to store records, examination marks, faculty details, and question papers. The system has three main user groups: Students, Faculty, and Administrators. Students should be able to view only their own marks and download permitted learning materials. Faculty members need to view student records and enter or modify marks. Administrators manage user accounts, permissions, and system configuration.

The university has assigned permissions through roles, but an audit review identifies the following events:

- At 10:00, the account Student07 has three failed login attempts.
- At 10:03 Student07 successfully logs in.
- ~~At 10:04, Student07 successfully logs in.~~
- At 10:04, Student07 attempts to open ExamMarks.xlsx, which contains marks for an entire class.
- At 10:05, the system records an attempted modification of ExamMarks by Student07.
- At 10:15, Faculty02 modifies marks in ExamMarks.xlsx and saves the file successfully.
- At 10:20, an administrator discovers that a former faculty member's account is still active.
- The audit log is stored on the same server, and users with broad permissions may be able to modify or delete it.

Page No.
Date

The university wants to protect confidentiality, integrity and availability; prevent unauthorized access; maintain accountability; and investigate suspicious activity. You are asked to recommend appropriate operating system access-control, security-administration, and auditing measures.

Questions

Q.1 Identify the main security problems in the case study (4 marks)

List at least four risks or weaknesses indicated by the scenarion.

→ 1. Weak or improper access permissions.
2. Former faculty accounts may still be active.
3. Marks of the entired were exposed, causing a confidentiality issue.
4. Three failed login attempts were recorded, which may indicate an attempt to access an account.

Q.2. Explain the ~~different~~ difference between authentication and authorization using student07 as an example. (4 marks)

~~Distin~~ Distinguish identity verification for permission checking.

→. Authentication → who are you?
It means checking who the user is.

Page No.
Date

Authorization → What are you allowed to do? It means checking what the user is allowed to do after logging in.

Q3. Recommend an access-control policy for students, faculty, and Administrators. Justify your choice (5 marks) Consider how ~~perms~~ permissions should be assigned and managed.

→ Students: They can ~~access~~ ~~the~~ ~~or~~ view only their own academic details.
Faculty: They can view and modify records related to their students.
Administrators: Manage user accounts, permissions and system configuration.

Q4 Prepare a suitable Access Control List (ACL) for Exam Marks .xlsx. (5 Marks)
Specify appropriate Read, Write, and Delete permissions for each user groups.

→

User Group	Read	Write	Delete
Students	Yes	No	No
Faculty	Yes	Yes	Yes
Administrators	Yes	Yes	Yes

Q.5 Explain how the principle of Least Privilege should be applied in this system. (4 marks)
State what each group needs to do and which unnecessary permissions should be removed.

→ The principle of least privilege means giving each user only the permissions they need to perform their work.
students: access only their own information.
faculty: access only their required student records
Administrators: get access only for administrative work.
Unnecessary permissions should be removed which are apart from the ones mentioned above.

Q.6 Interpret the audit events from 10:00 to 10:05. What should the security team do next? (5 marks)
Explain why the sequence is suspicious without assuming that it proves an attack.

→ The sequence shows multiple failed login attempts followed by system access within a short time. This is suspicious because someone may have been trying to gain unauthorized access. However, it does not confirm that an attack actually happened.
The security team should check the audit logs, IP addresses and account activity.

They should verify the user and monitor the account for any further suspicious activity.

Q.7 Identify at least five events that should be recorded in the audit logs.

→ 1. User login and logout
2. Failed login attempts
3. File access and modifications.
4. Changes to user permissions.
5. Creation or deletion of user accounts.

Q.8. Explain why the audit logs must be protected and recommend two ways to protect them (3 mks). Consider unauthorized modification, deletion, and investigation.

→ Audit logs should be protected to prevent unauthorized modification or deletion of important records. They help the security team investigate suspicious activities and find out what happened.
They should be accessible only to authorized users and stored secured with proper backups.

Q.9. What action should be taken regarding the former faculty member's active account? Explain (3 mks). Relate your answer to account management and access removal.

→ The former faculty member's account should be disabled immediately after leaving the university. All their access rights and permissions should be removed.
The account should be reviewed regularly to ensure that inactive accounts do not remain active.

Q.10 Suggest a practical incident-response and corrective-action plan for the university. [4 mks.

Include investigation, access review, policy changes, and follow-up monitoring.

→ • Investigate the suspicious activity using audit logs.
• Review user accounts and permissions and remove unnecessary access.
• Update security policies for passwords, access control and account removal.
• Monitor the system regularly and follow up on any further suspicious activity.